Control ID	Control Theme	Control Objective
CM-001	Access Control	Restrict access to systems and sensitive data based on business need
CM-002	Authentication / MFA	Verify user identity and strengthen access security for critical systems
CM-003	Logging and Monitoring	Capture and review relevant security events to support detection and response
CM-004	Vendor Management	Assess and monitor third-party providers that support critical services or handle sensitive data
CM-005	Data Retention / Minimization	Retain only necessary data for defined periods and dispose of it appropriately
CM-006	Change Management	Ensure system changes are approved, tested, and documented before production release
CM-007	Vulnerability Management	Identify, assess, and remediate vulnerabilities in systems and applications
CM-008	Incident Response	Detect, escalate, respond to, and recover from security incidents in a structured manner
CM-009	Encryption / Data Protection	Protect sensitive data through encryption and secure handling practices
CM-010	Policy and Governance Oversight	Establish and maintain governance direction, policy expectations, and oversight for security and compliance

Business Risk Addressed	PCI DSS Reference
Unauthorized access, excessive privilege, data exposure, compliance failure	Req. 7
Account compromise, unauthorized administrative access, fraud risk	Req. 8
Late detection of incidents, weak accountability, investigation failure	Req. 10
Third-party failure, data exposure, operational disruption, compliance risk	Req. 12
Over-retention, privacy exposure, regulatory non-compliance, excess breach impact	Req. 3
Unauthorized changes, service disruption, compliance gaps, weak accountability	Req. 6
Exploitation of known weaknesses, compromise of sensitive systems, compliance failure	Req. 11
Delayed response, uncontrolled incident impact, reporting failure, weak recovery	Req. 12
Data exposure, unauthorized disclosure, regulatory non-compliance, customer trust loss	Req. 3 and Req. 4
Weak accountability, inconsistent control execution, unmanaged compliance exposure	Req. 12

SkyBridge Airline – Control Mapping Matrix

NIST CSF Function	ISO 27001 Reference	CIS Controls Reference
Protect	Annex A - Access Control	CIS Control 6
Protect	Annex A - Identity Management and Authentication	CIS Control 6
Detect	Annex A - Logging and Monitoring	CIS Control 8
Identify	Annex A - Supplier Relationships	CIS Control 15
Protect	Annex A - Information Deletion and Data Retention	CIS Control 3
Protect	Annex A - Change Management	CIS Control 4
Identify / Protect	Annex A - Technical Vulnerability Management	CIS Control 7
Respond / Recover	Annex A - Information Security Incident Management	CIS Control 17
Protect	Annex A - Cryptography and Data Protection	CIS Control 3
Govern / Identify	Clauses 4-10 and Annex A Governance Themes	CIS Control 17 and CIS Control 18

GDPR / CCPA Relevance	Typical Owner	Example Evidence
Relevant where personal data access must be limited	IAM Manager	Access review reports, role matrix, approval records
Indirectly relevant where access to personal data must be protected	IAM Manager	MFA configuration screenshots, authentication policy, enrollment records
Relevant where logs support protection and investigation of personal data incidents	Security Operations Lead	SIEM screenshots, log review records, retention settings
Highly relevant where vendors process personal data or support regulated functions	Vendor Management Lead	Due diligence checklist, vendor review records, SLA review notes
Directly relevant to privacy obligations	Data Protection Officer	Retention schedule, deletion standard, data handling procedure
Indirectly relevant where system changes affect personal data handling	IT Operations Manager	Change tickets, approvals, test records, implementation logs
Indirectly relevant where vulnerabilities could expose personal data	Vulnerability Management Lead	Scan results, remediation tracker, patch records
Highly relevant where incidents involve personal data breaches	Security Operations Lead	Incident response plan, incident tickets, tabletop records, lessons learned log
Directly relevant where personal data must be protected	Data Protection Officer	Encryption settings, key management procedure, transmission security settings
Relevant where policy and governance support privacy obligations and accountability	Head of Compliance	Policies, committee minutes, governance reports, exception log

Control Maturity / Status	Notes / Mapping Insight
Partially Implemented	Strong overlap across security and privacy requirements; privacy relevance increases when personal data is involved
Partially Implemented	PCI DSS is more prescriptive here than broader frameworks; privacy link is indirect but important
Partially Implemented	Strong security overlap; privacy relevance appears when incident handling or personal data protection is involved
Partially Implemented	One of the strongest cross-framework control themes because it connects security, operations, compliance, and privacy
Needs Improvement	This control has stronger privacy weight than some security controls, though it still overlaps with PCI DSS data protection expectations
Partially Implemented	Strong operational and audit relevance; privacy link appears when changes affect regulated data processes
Needs Improvement	PCI DSS is explicit about testing and scanning; broader frameworks focus on ongoing risk reduction
Partially Implemented	Strong cross-framework relevance; privacy obligations become more direct during breach handling and notification
Partially Implemented	Strong overlap across payment security and privacy; PCI DSS is more prescriptive around cardholder data handling
Partially Implemented	This is the umbrella layer that helps make the other controls sustainable; ISO 27001 emphasizes governance structure more strongly than CIS